

Security Policy

Owner: Transformative Leadership Lab LLC · **Applies to:** Meeting Cost Meter (Zoom App)

Contact: thomas+mcsupport@txl-lab.com · **Effective:** 25 June 2026 · **Review:** annually or on material change

This policy describes controls actually in place for a small-team operation. It claims no SOC 2 / ISO 27001 certification and no third-party penetration testing.

Purpose & scope

Defines how we protect the Meeting Cost Meter application, its hosted service, and the data entrusted to it.

Data classification

- **Presenter configuration** (attendee count + one hourly opportunity-cost estimate + display cadence): treated as confidential; **held only in the browser session and never persisted server-side**. Never wages/salaries — we do not request or store pay data.
- **Zoom OAuth tokens:** secret; used only to authenticate and operate; not exposed to other users.
- **Operational logs / client diagnostics:** low sensitivity; the server logs `[server] METHOD path` request lines plus the client diagnostics/errors POSTed to `/api/log`. **The client diagnostics are minimized at the source** — the probe sends only the data *shape* of Zoom SDK responses (field names/lengths/counts, never values) and error reports carry a fixed field set (error text/stack, path, user agent). The endpoint records the submitted body, so logs are **not intentionally populated** with secrets, the presenter's figures, or participant data rather than guaranteed free of them. See `data-retention-and-protection.md`.

Controls

- **Encryption in transit:** HTTPS/TLS enforced (HSTS).
- **No data at rest:** the app persists no presenter configuration server-side — settings are session-only, so there is nothing stored to encrypt or protect at rest.
- **Secrets management:** all credentials are environment variables, injected per environment; never committed. A pre-commit secret-scanning hook blocks credential commits.
- **Access control:** the source repository (GitHub) and hosting (Railway) are accessed through individual accounts; account owners are expected to enable multi-factor authentication. `main` is a protected branch: changes merge only via reviewed pull request with all required status checks passing (see [SSDLC § Merge control](#)).
- **Secure headers:** CSP, `nosniff`, `Referrer-Policy`, and `no-store` on all responses.

- **Input validation:** request bodies to the server (e.g. the `/api/log` diagnostics sink) are size-bounded; client inputs (attendee count, rate) are clamped to non-negative numbers.
- **Automated testing & SAST:** see `ssdlc.md` (tests, CodeQL, Dependabot).

Third parties / sub-processors

- **GitHub** — source control and CI (CodeQL, Dependabot).
- **Railway** — application hosting.
- **Zoom** — the platform the app runs within (SDK, OAuth).

No other third-party data processors. No analytics, advertising, or tracking SDKs.

Responsibilities

The application owner (Transformative Leadership Lab LLC) is responsible for maintaining these controls, triaging reports sent to the contact above, and reviewing this policy on the cadence stated in the header.

Related documents

`ssdlc.md` · `vulnerability-management.md` · `data-retention-and-protection.md` · `incident-response.md` · `dependency-management.md` · public Privacy Policy (<https://thomasbcox.github.io/zoom-meeting-cost/privacy.html>).